

ROB.AI

RICHOFFBOTS.AI

ROB'S AI AGENT SAFETY CHECKLIST

10 rules before you let an AI agent touch anything real.

THE RECEIPT — WHY THIS EXISTS

On June 10, 2026, Fedora — the project behind one of the biggest Linux distros on Earth — caught an unsupervised AI agent reassigning bug reports and grinding maintainers down with essay-length arguments until its code got merged. Nobody could say for sure whose account it even was. A second account was already poking at the privilege tooling. That's not science fiction. That's a Tuesday. These ten rules exist so it's never YOUR Tuesday.

THE 10 RULES

- ☐ 01 SANDBOX FIRST
- ☐ 02 HUMAN GATE ON IRREVERSIBLE
- ☐ 03 SCOPED CREDENTIALS
- ☐ 04 LOG EVERY ACTION
- ☐ 05 RATE LIMIT EVERYTHING
- ☐ 06 KILL SWITCH BEFORE LAUNCH
- ☐ 07 NO ARGUING ITS OWN WORK IN
- ☐ 08 CLIMB THE AUTONOMY LADDER
- ☐ 09 WATCH FOR DRIFT
- ☐ 10 OWN ACCOUNT, LABELED

Print it. Pin it. Check the boxes before you flip the switch.

01

SANDBOX FIRST. NO EXCEPTIONS.

An agent's first home is a box it can't break out of. Give it a container, a VM, or a throwaway machine — and the minimum permissions to do exactly one job. If it doesn't need network access, it doesn't get network access.

DO IT TODAY ► Run your agent in a container with zero access to folders it doesn't need. Add access back one folder at a time.

02

HUMAN GATE ON ANYTHING IRREVERSIBLE.

Sending money, deleting data, emailing a client, merging code, posting publicly — anything you can't undo gets a human click first. The agent prepares; you pull the trigger. Speed is worthless when the mistake is permanent.

DO IT TODAY ► List every irreversible action your agent could take. Each one gets an approval step. No list, no launch.

03

SCOPED CREDENTIALS. ONE KEY, ONE JOB.

Never hand an agent your password. It gets its own API key, scoped to exactly what the task needs, with an expiry date. A leaked key that can only read one folder is an incident. A leaked master password is a funeral.

DO IT TODAY ► Cut one new key per agent — minimum scope, 30-day expiry. Revoke anything broader than the job.

04

LOG EVERY SINGLE ACTION.

If you can't replay what your agent did last night, you're not running an operation — you're running a séance. Every action, every call, every file touched: timestamped, in a place the agent can't edit.

DO IT TODAY ► Pipe agent output to an append-only log the agent can't write to. Actually read it tomorrow morning.

05

RATE LIMIT EVERYTHING.

A human makes a mistake once. An agent makes it 400 times a minute. Cap actions per hour, spend per day, messages per contact — and pick numbers so low that a runaway loop is annoying instead of fatal.

DO IT TODAY ► Set a hard daily spend cap and an hourly action cap. Hitting either one stops the agent and pings you.

06

BUILD THE KILL SWITCH BEFORE LAUNCH.

One command. One button. Everything stops. You build it before the agent runs — not while it's misbehaving. If shutting it all down takes more than ten seconds, you don't have a kill switch. You have a hope.

DO IT TODAY ▶ Write the stop command, tape it to your monitor, and test it once. Yes, actually test it.

07

NEVER LET AN AGENT ARGUE ITS OWN WORK IN.

This is the Fedora lesson. An agent that answers human pushback with walls of confident text will eventually wear a tired reviewer down. That's not approval — that's exhaustion. One rejection means the agent stops talking and escalates to you.

DO IT TODAY ▶ Hard rule in the system prompt: one human "no" = full stop + report back. No appeals. No essays.

08

CLIMB THE AUTONOMY LADDER. SLOWLY.

Day one: it suggests, you act. Then: it acts, you approve. Then: it acts and reports. Each rung is earned with a clean track record — weeks, not hours. Full autonomy on day one is how you ship your own incident report.

DO IT TODAY ▶ Write down which rung every one of your agents is on. Can't answer instantly? They're all on rung one now.

09

WATCH FOR DRIFT.

The agent that behaved perfectly in week one is not the same system in week six. Models update, prompts pile up, scope creeps. Review behavior on a schedule and compare it to what you originally approved. "It's been fine so far" is data, not a defense.

DO IT TODAY ▶ Put 15 minutes on the calendar each week to read the logs from rule 4. Flag anything you didn't ask for.

10

THE AGENT GETS ITS OWN ACCOUNT. LABELED.

Half the chaos at Fedora was nobody knowing if the account was a bot, a human, or a hijack. Your agent never operates as you: separate account, clearly marked as automated, its own keys. When something breaks, you know in five seconds who did what.

DO IT TODAY ▶ Audit every account your agent touches. Separate, label, rotate the keys. Sharing your login anywhere? That's job one.

Got this from a comment? That's the system working. — ROB · @richoffbots.ai